Blacksheep

POLICY DOCUMENT

Sensitive Data Policy

Blacksheep Operations Pty Ltd & Flux Interactive Pty Ltd

Parties	Blacksheep Operations Pty Ltd & Flux Interactive Pty Ltd
Classification	Internal
Review Cycle	Annually, or following any data incident
Owner	Samuel Thompson-Kennedy
Last Reviewed	10 April 2026

1. Purpose

This policy is jointly adopted by Blacksheep Operations Pty Ltd ("Blacksheep") and Flux Interactive Pty Ltd ("Flux"). It defines how sensitive data processed by the Blacksheep platform is classified, handled, stored, and protected. Blacksheep is the owner of all user and operational data; Flux owns and operates the infrastructure on which that data is stored and processed. This policy ensures that data handling practices meet the requirements of the Australian Privacy Act 1988 and the expectations of Blacksheep's stakeholders.

2. Scope

This policy applies to all data processed, stored, or transmitted by Blacksheep systems, including:

- Data held in databases
- Data exchanged with third-party providers
- Data visible in admin interfaces, logs, or monitoring tools
- Data held in backups

3. Data Classification

LEVEL	DEFINITION
CRITICAL	Cryptographic material, authentication secrets, and signing keys. Compromise would allow unauthorised operations.
RESTRICTED	Personally identifiable information (PII) and financial data. Subject to privacy legislation and regulatory obligations.
INTERNAL	Operational data that is not sensitive on its own but could aid an attacker if combined with other information.
PUBLIC	Information intended for or already available to the public.

4. Data Inventory

The following table describes the categories of sensitive data held by Blacksheep and their handling. For storage locations and data processing details, see Appendix A and Appendix B.

DATA CATEGORY	CLASSIFICATION	ACCESS	RETENTION
User Authentication identity	RESTRICTED	Application-level only	Account lifetime (subject to regulatory holds)
Bank account and wallet details	RESTRICTED	Application-level only	Indefinite (regulatory requirement)
Transaction records	RESTRICTED	Application-level only	Indefinite (regulatory requirement)
Account balances	RESTRICTED	Application-level only	Real-time; historical via transactions
Risk & AML screening results	RESTRICTED	Application-level; authorised staff	Indefinite (regulatory requirement)
Internal notes (staff notes on users/accounts)	RESTRICTED	Admin portal (authorised staff)	Indefinite (regulatory requirement)
API keys & provider secrets	CRITICAL	Irrevocably sealed; senior engineering only	Rotated per provider requirements

DATA CATEGORY	CLASSIFICATION	ACCESS	RETENTION
Cryptographic signing keys	CRITICAL	Key management service; IAM-controlled	Key lifetime (managed via KMS)
Application and infrastructure logs	INTERNAL	Authorised staff via observability tooling	90 days (see Security Policy §7)

5. Data Handling Principles

5.1 DATA MINIMISATION

- Blacksheep collects only the data necessary to provide its services and meet regulatory obligations.
- Identity verification is handled by Blacksheep's designated third-party providers. Flux integrates these providers into the platform but does not own or store identity documents. Blacksheep retains basic identity data but not identity document information.
- Wallet custody and signing is managed by a third-party provider. Blacksheep does not hold complete private keys of users. Transaction signing is managed by a third-party provider.

5.2 ACCESS CONTROL

CLASSIFICATION	WHO CAN ACCESS	HOW
CRITICAL	Senior Flux engineering only, authorised by Blacksheep founder	Key management service, sealed secrets manager
RESTRICTED	Application layer; authorised admin staff	Application code; admin portal
INTERNAL	Authorised personnel	Observability tooling, infrastructure dashboards
PUBLIC	Anyone	Public endpoints

- No personnel have direct database access in the normal course of operations.
- Production database credentials are sealed within the infrastructure secrets manager.
- Admin portal access is authenticated and restricted to authorised Blacksheep staff.

5.3 LOGGING & SENSITIVE DATA

- Application and infrastructure logs must not contain PII, credentials, or financial data.
- Structured logging is configured to exclude sensitive fields.

6. Data Shared with Third Parties

Blacksheep shares limited data with third-party providers to deliver its services. The principle of data minimisation applies — only the data required for the specific service is shared.

CATEGORY	DATA SHARED
Banking / Payments	Fiat transaction instructions, account references, travel rule and personal information required by relevant jurisdiction regulators
Crypto Exchange	Trade instructions, balances
Identity Verification	Identity data (via third-party provider flow)
AML / Compliance	Wallet addresses, transaction data
Blockchain Relay	Signed transaction data
Wallet Custody	Unsigned transaction data
Email	User email addresses, transactional content
Support	Support ticket content

Third-party providers store data in their own infrastructure according to their own data residency and retention policies. For a list of third-party providers used, see Appendix B.

---

7. Data Retention & Disposal

DATA TYPE	RETENTION PERIOD	DISPOSAL METHOD
User account data	Account lifetime; deleted upon closure (subject to regulatory holds)	Soft delete, then hard delete after hold period
Transaction records	Indefinite (regulatory requirement)	N/A
Identity data metadata	Account lifetime	Deleted with "User account data"; source records held by provider
Database backups	Per backup schedule (see Security Policy, Section 4.3)	Automatic expiry

DATA TYPE	RETENTION PERIOD	DISPOSAL METHOD
Application and infrastructure logs	90 days (see Security Policy §7)	Automatic expiry
Sealed secrets	Until rotated	Overwritten on rotation; prior values irrecoverable

When data is deleted from the production database, it will naturally expire from backups according to the backup retention schedule. No separate backup purge process is required.

---

8. Breach Notification

In the event that sensitive data is compromised:

1. Follow the Incident Response procedure in the Security Policy (Section 8).
2. Notify Blacksheep's compliance team immediately if Restricted or Critical data is affected.
3. Both Flux and Blacksheep are APP entities under the Privacy Act 1988 and each carry independent notification obligations under the Notifiable Data Breaches (NDB) scheme administered by the Office of the Australian Information Commissioner (OAIC). As the principal data controller, Blacksheep will ordinarily lead NDB assessment and notification to the OAIC and affected individuals. Flux will notify directly only where Blacksheep has not fulfilled its NDB obligations within the statutory timeframe, to Flux's satisfaction.

---

9. Staff Obligations

All personnel with access to Blacksheep systems must:

- Not extract, copy, or store sensitive data on personal devices or external storage.
- Not share credentials, API keys, or access tokens with unauthorised parties.
- Not access user data beyond what is required for their role.
- Report any suspected data exposure or policy violation immediately.
- Use secure, up-to-date devices when accessing Blacksheep infrastructure.

---

10. Data Subject Rights

Under the Australian Privacy Principles (APPs 12 and 13), individuals have the right to access personal information held about them and to request correction of inaccurate information. As the principal data controller, Blacksheep is responsible for receiving and responding to these requests. Flux will provide technical support to locate, export, or correct personal information where required to fulfil a valid request.

11. Policy Review

This policy is reviewed annually or immediately following:

- A data breach or suspected breach
- A change in data handling practices or architecture
- A change in applicable legislation or regulatory guidance
- A change in personnel with access to sensitive data
- A request from either party or a regulatory body